COMPTIA SECURITY+ SY0-701 | DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.3 · States of Data

Mestre CyberSec · **Aula 3.3 — States of Data** (6:07) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: 3 estados: AT REST (parado no disco — BitLocker/DEB); IN TRANSIT (viajando — TLS/VPN); IN USE (sendo processado na memória — confidential computing/enclaves). O mais difícil de proteger é o in use.

💡 Highlights que a prova CompTIA cobra

- At rest: disco; In transit: rede; In use: memória
- TLS=transit; BitLocker=TDE+rest; enclaves=use

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'data being processed in memory'=in use

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.3 — States of Data)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Dados em repouso (DAR)

Dados armazenados em mídia física, como disco, banco de dados ou backup, que não estão em trânsito na rede nem sendo processados na memória. Proteja com criptografia, controles de acesso e descarte seguro.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar de disco, arquivo salvo, banco de dados ou backup, é at rest. BitLocker/FDE e TDE são controles típicos.*

• Dados em trânsito (DIT)

Dados em movimento através de uma rede entre sistemas, aplicações ou usuários. Proteja com TLS, VPN, SSH ou IPsec.

⚠️ ***Armadilha CompTIA:*** *Se mencionar rede, tráfego, HTTP/HTTPS, e-mail ou VPN, é in transit. TLS protege trânsito, não repouso.*

• Dados em uso (DIU)

Dados sendo processados na memória por uma CPU, aplicação ou runtime. É considerado o estado mais difícil de proteger e pode exigir confidential computing ou enclaves seguros.

⚠️ ***Armadilha CompTIA:*** *Palavra-chave 'processed in memory' = in use. Não confunda com at rest (disco) nem in transit (rede).*

• Criptografia de disco completo (FDE)

Criptografa um dispositivo de armazenamento inteiro para proteger todos os dados em repouso se o dispositivo for perdido ou roubado. BitLocker é uma implementação comum no Windows.

⚠️ ***Armadilha CompTIA:*** *FDE/BitLocker = at rest. Não protege dados em uso depois que o sistema está ligado e desbloqueado.*

• BitLocker (N/A)

Recurso de criptografia de volume completo do Microsoft Windows que protege dados em repouso, geralmente usando TPM para proteção de chaves. É um exemplo comum de criptografia de disco completo.

⚠️ ***Armadilha CompTIA:*** *Se a prova citar BitLocker, pense at rest/FDE no disco. Pode usar TPM para armazenar chaves.*

• Segurança da Camada de Transporte (TLS)

Protocolo criptográfico que fornece criptografia e integridade para dados em trânsito entre clientes e servidores, comumente usado por HTTPS. Não protege dados em repouso ou em uso.

⚠️ ***Armadilha CompTIA:*** *TLS = in transit. HTTPS usa TLS. Não é criptografia de disco nem de memória.*

• Rede Privada Virtual (VPN)

Cria um túnel criptografado para dados em trânsito em uma rede não confiável, como a Internet. Protege o tráfego de rede, não dados armazenados nos endpoints.

⚠️ ***Armadilha CompTIA:*** *VPN = in transit. Protege tráfego de rede, não dados parados no disco.*

• Computação Confidencial / Enclave Seguro (N/A)

Protege dados em uso isolando o processamento dentro de um ambiente de execução confiável baseado em hardware ou enclave. Impede que o sistema operacional host ou outros processos acessem os dados enquanto são processados.

⚠️ ***Armadilha CompTIA:*** *Enclaves/confidential computing = in use. Se mencionar dados em processamento na memória, escolha in use.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Data at Rest (DAR - Dados em Repouso)

🏠 **Analogia Intuitiva:** Uma barra de ouro guardada no fundo do cofre de aço no porão de um banco. Ela não está se movendo pela rodovia nem sendo derretida na mão do joalheiro naquele momento; está apenas parada esperando no cofre. Porém, se um ladrão conseguir invadir o banco à noite e a porta do cofre estiver aberta sem chave (disco rígido sem criptografia), ele coloca a barra na mochila e sai andando tranquilamente.

🔍 **Causa Raiz / Por que foi criado:** Dispositivos físicos de armazenamento (laptops corporativos, pendrives, fitas de backup antigas e discos de servidores) são facilmente esquecidos em táxis, furtados de escritórios ou descartados no lixo sem higienização adequada de sanitização.

🛡️ **Visão do Auditor de GRC:** Imposição de Criptografia Total de Disco (FDE - Full Disk Encryption via BitLocker/FileVault) em 100% dos computadores móveis com chaves gerenciadas por TPM; uso de SED (Self-Encrypting Drives) em storages; e exigência de certificados de desmatamento/desmagnetização e trituração física (Degaussing/Shredding) para mídias descartadas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'laptop stolen from an employee vehicle; company avoids breach notification penalties because hard drive was protected by Full Disk Encryption (FDE)' = Data at Rest. Outro gatilho: 'protecting static databases in SAN/NAS volumes or tape archives'.

📌 Data in Transit / In Flight (DIT - Dados em Trânsito)

🏠 **Analogia Intuitiva:** Um mensageiro transportando uma maleta de documentos confidenciais de moto no meio de uma avenida com trânsito pesado. Se a maleta for feita de plástico transparente (protocolos sem criptografia como HTTP ou FTP), qualquer pedestre ou motorista ao lado consegue ler o contrato com facilidade. Mas se a maleta for um baú blindado de titânio trancado com segredo numérico e escoltado por batedores (túnel criptografado HTTPS/TLS ou VPN IPsec), ninguém na rodovia consegue ver nem trocar as páginas.

🔍 **Causa Raiz / Por que foi criado:** Redes de computadores — em especial conexões Wi-Fi públicas de cafeterias e a própria Internet aberta — são vias compartilhadas suscetíveis à interceptação de pacotes (sniffing), ataques de envenenamento ARP e ataques On-path (Man-in-the-Middle).

🛡️ **Visão do Auditor de GRC:** Desativação mandatória de protocolos em texto claro (bloqueio de portas 80/HTTP, 21/FTP, 23/Telnet em firewalls); imposição do TLS 1.3 em todos os serviços web corporativos; e uso obrigatório de VPNs corporativas criptografadas com MFA para colaboradores remotos.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'prevent packet sniffing, session interception, or eavesdropping over untrusted networks' = Data in Transit / TLS / IPsec / SSH. Pegadinha: se a questão mencionar dados trafegando entre switches locais ou nuvem pública, continua sendo 'in transit'.

📌 Data in Use / In Process (DIU - Dados em Processamento / Memória)

🏠 **Analogia Intuitiva:** O chefe de cozinha preparando um banquete requintado com a folha da receita secreta aberta bem no meio da bancada de inox da cozinha. Enquanto os ingredientes estão na panela sob o fogo (processados pela CPU) e a folha está aberta na bancada (carregada na memória RAM), qualquer pessoa que passar por ali consegue espiar a receita ou colocar veneno na panela, mesmo que o armário de temperos tenha ficado trancado a chave.

🔍 **Causa Raiz / Por que foi criado:** Para que os microprocessadores consigam somar, buscar ou comparar informações, os dados precisam ser descriptografados e mantidos em texto puro na memória RAM e nos registradores da CPU, onde malwares com privilégios de administrador (como Mimikatz ou RAM scrapers) conseguem capturá-los via despejos de memória (memory dump).

🛡️ **Visão do Auditor de GRC:** Auditoria de controles avançados de integridade de memória: Computação Confidencial (Confidential Computing), uso de enclaves seguros de hardware (Hardware Secure Enclaves como Intel SGX e AMD SEV), bloqueio de despejos de memória e proteção de credenciais como Windows Defender Credential Guard.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'data residing in system RAM, CPU registers, or application runtime memory being actively modified or analyzed' = Data in Use. Defesa moderna de ponta na prova SY0-701: Confidential Computing / Enclaves Seguros de Hardware.

📌 Visão Holística de GRC dos Três Estados de Dados (Defense-in-Depth dos Dados)

🏠 **Analogia Intuitiva:** Um serviço de transporte de valores bancários: o cofre blindado na agência de saída protege o dinheiro parado (DAR); o caminhão blindado com escolta armada protege o dinheiro na rodovia (DIT); e a cabine fechada com câmeras e operador revistado protege o dinheiro no momento exato em que as notas são contadas e separadas na mesa (DIU). Se o banco descuidar de uma única etapa, os criminosos realizam o assalto exatamente nela.

🔍 **Causa Raiz / Por que foi criado:** A falácia clássica de segurança onde a organização gasta todo o seu orçamento de segurança em túneis SSL/TLS para a rede (DIT), mas deixa o banco de dados desprotegido em disco rígido aberto (DAR) ou permite que técnicos despejem a memória RAM de servidores em arquivos de log sem proteção (DIU).

🛡️ **Visão do Auditor de GRC:** Mapeamento formal do Ciclo de Vida dos Dados (Data Lifecycle Mapping) na documentação de governança SOC 2 e ISO 27001; validação de que os relatórios de análise de risco avaliam e documentam contramedidas específicas para os três estados simultaneamente.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'comprehensive data protection program requires technical controls implemented across all stages of the data lifecycle'. Identifique os três estados: Data at Rest, Data in Transit e Data in Use.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Notebook corporativo furtado do porta-malas do carro com banco de dados de clientes no HD	**Dados em Repouso (Data at Rest - DAR) protegido por BitLocker / FDE**
Interceptação de credenciais de login e dados financeiros trafegando pelo Wi-Fi público de um aeroporto	**Dados em Trânsito (Data in Transit - DIT) protegido por TLS 1.3 / IPsec VPN**
Malware injetado na memória RAM de um ponto de venda (POS) para raspar números de cartão de crédito durante o processamento	**Dados em Uso (Data in Use - DIU) protegido por Computação Confidencial / Enclave Seguro**
Controle que assegura que discos rígidos antigos descartados não permitam a recuperação forense de segredos industriais	**Sanitização de Mídia em Repouso (Degaussing / Purging / Physical Shredding)**
Mecanismo criptográfico de hardware que isola trechos de código e dados em execução contra o próprio sistema operacional comprometido	**Enclave Seguro de Hardware / TPM (Hardware Secure Enclave)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital fornece laptops para enfermeiros. Um laptop contendo prontuários de pacientes é roubado de um carro trancado. A equipe de segurança precisa garantir que, se o disco for removido e conectado a outro computador, os registros armazenados permaneçam ilegíveis. Qual controle atende melhor a esse requisito?

A) Criptografia de sessão TLS para o portal de prontuários eletrônicos

B) Túnel VPN para acesso remoto à rede do hospital

C) Criptografia de disco completo, como BitLocker

D) Enclave seguro para processar prontuários de pacientes na memória

QUESTÃO 2 · CENÁRIO DE EXAME

O checkout online de uma empresa de varejo envia dados de cartão de pagamento dos navegadores dos clientes para seus servidores web pela internet pública. O arquiteto de segurança quer impedir interceptação e adulteração durante a transmissão. Qual tecnologia deve ser implementada?

A) Transport Layer Security (TLS)

B) Criptografia de disco completo nos servidores web

C) Criptografia em nível de coluna no banco de dados de pagamentos

D) Um enclave seguro no servidor de aplicação

QUESTÃO 3 · CENÁRIO DE EXAME

Um analista financeiro trabalha em uma cafeteria e precisa acessar compartilhamentos internos de arquivos contendo relatórios trimestrais. A empresa exige que o tráfego entre o laptop do analista e a rede corporativa seja criptografado pela Wi-Fi pública não confiável. Qual solução atende melhor a esse requisito?

A) BitLocker To Go nas portas USB do laptop

B) Uma conexão VPN com a rede corporativa

C) Criptografia transparente de banco de dados no servidor de arquivos

D) Criptografia de memória para o aplicativo de planilhas do analista

QUESTÃO 4 · CENÁRIO DE EXAME

Um provedor de nuvem executa cargas de trabalho de vários clientes no mesmo host físico. Um cliente regulamentado quer garantia de que seus dados não possam ser vistos pelo administrador do hypervisor enquanto a carga de trabalho está sendo processada ativamente na memória. Qual abordagem atende melhor a essa preocupação?

A) Criptografar o disco virtual com BitLocker em todos os clusters corporativos internos

B) Exigir TLS para todas as sessões do console de gerenciamento durante janelas agendadas de manutenção administrativa

C) Armazenar backups em um bucket S3 criptografado antes de encaminhar requisições aos serviços backend

D) Usar computação confidencial com enclaves seguros baseados em hardware

QUESTÃO 5 · CENÁRIO DE EXAME

Um CISO está priorizando investimentos de segurança ao longo do ciclo de vida dos dados. A equipe observa que alguns controles protegem arquivos armazenados, outros protegem sessões de rede e outros protegem informações enquanto aplicações e CPUs estão trabalhando ativamente nelas. Qual estado dos dados é geralmente o mais difícil de proteger porque precisa ser exposto na memória para processamento?

A) Dados em uso

B) Dados em repouso

C) Dados em trânsito

D) Dados em arquivo

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa de comércio eletrônico armazena seu banco de dados de clientes em uma storage area network. Um atacante obtém acesso físico ao data center e rouba vários discos. A empresa quer garantir que os arquivos do banco de dados não possam ser lidos quando os discos forem conectados a outro sistema. Qual controle é mais apropriado?

A) Autenticação mútua TLS entre nós de banco de dados

B) Acesso VPN para administradores de banco de dados aplicando políticas rigorosas de menor privilégio

C) Criptografia de disco completo nos volumes de armazenamento

D) Um ambiente de execução confiável para consultas de banco de dados

QUESTÃO 7 · CENÁRIO DE EXAME

Uma arquitetura de microsserviços envia tokens de autenticação e dados pessoais entre serviços internos dentro de um cluster Kubernetes. A equipe de segurança está preocupada com movimento lateral e ataques man-in-the-middle entre serviços, mesmo que o tráfego permaneça dentro do data center. Qual controle protege melhor esse tráfego?

A) Criptografia de disco completo nos volumes dos nós de trabalho

B) Enclaves seguros para a memória de cada contêiner

C) BitLocker To Go em laptops de administradores

D) TLS mútuo (mTLS) entre serviços

QUESTÃO 8 · CENÁRIO DE EXAME

Um funcionário de RH copia uma planilha contendo salários de funcionários para um pen drive USB para trabalhar nela em casa. O pen drive é perdido depois. A empresa quer reduzir o risco de que qualquer pessoa que encontre o drive consiga ler a planilha. Qual controle deve ser aplicado ao pen drive USB?

A) TLS para transferências de arquivos eliminando pontos únicos de falha entre endpoints

B) BitLocker To Go com uma senha forte ou cartão inteligente

C) VPN no roteador doméstico do funcionário em todos os perímetros da zona desmilitarizada

D) Um enclave seguro no laptop do funcionário em todos os ambientes corporativos em nuvem

QUESTÃO 9 · CENÁRIO DE EXAME

Um serviço de gerenciamento de chaves precisa processar chaves criptográficas na memória para realizar operações de assinatura. A equipe de segurança teme que um administrador malicioso ou malware faça dump da memória do processo e extraia as chaves. Qual tecnologia protege melhor as chaves enquanto elas estão sendo usadas?

A) Enclave seguro baseado em hardware ou ambiente de computação confidencial

B) Criptografia de disco completo no servidor de gerenciamento de chaves em todos os perímetros da zona desmilitarizada

C) TLS para todas as conexões administrativas em todos os ambientes corporativos em nuvem

D) RAID 6 nos discos do servidor de gerenciamento de chaves sem alterar as regras existentes de firewall

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa envia arquivos de folha de pagamento todas as noites de sua sede para um processador de folha de pagamento pela internet. O processador de folha de pagamento precisa verificar que os arquivos não foram modificados durante a transmissão e que vieram da empresa. Qual controle fornece melhor essas proteções para os dados enquanto estão em movimento?

A) Criptografia de disco completo nos servidores de ambas as organizações

B) Enclaves seguros nos servidores de processamento de folha de pagamento

C) Criptografia de banco de dados em repouso no processador de folha de pagamento

D) TLS com certificados de servidor e cliente

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Criptografia de disco completo, como BitLocker

O risco é dado em repouso em um disco roubado. A criptografia de disco completo, como BitLocker, criptografa todo o volume para que os prontuários permaneçam ilegíveis se o disco for removido e conectado a outro sistema. TLS e VPN protegem dados em trânsito, enquanto um enclave seguro protege dados em uso na memória.

Questão 2: Alternativa A — Transport Layer Security (TLS)

O TLS protege dados em trânsito criptografando o tráfego web e ajudando a detectar adulteração entre o navegador e o servidor. Criptografia de disco completo e criptografia em nível de coluna protegem dados em repouso, enquanto um enclave seguro protege dados em uso durante o processamento.

Questão 3: Alternativa B — Uma conexão VPN com a rede corporativa

Uma VPN criptografa dados em trânsito por redes não confiáveis, como Wi-Fi pública. BitLocker To Go e criptografia transparente de banco de dados protegem dados em repouso, enquanto criptografia de memória trata dados em uso.

Questão 4: Alternativa D — Usar computação confidencial com enclaves seguros baseados em hardware

A preocupação é dado em uso enquanto é processado ativamente na memória. Computação confidencial com enclaves seguros baseados em hardware isola a memória do hypervisor e de outros inquilinos. BitLocker e backups criptografados protegem dados em repouso, e TLS protege dados em trânsito.

Questão 5: Alternativa A — Dados em uso

Dados em uso são geralmente o estado mais difícil de proteger porque precisam ser descriptografados e ficar disponíveis na memória ou em registradores da CPU para processamento. Dados em repouso e em trânsito podem frequentemente ser protegidos com tecnologias de criptografia maduras, e dados arquivados são uma forma de dados em repouso.

Questão 6: Alternativa C — Criptografia de disco completo nos volumes de armazenamento

Discos roubados representam dados em repouso. Criptografia de disco completo nos volumes de armazenamento mantém os arquivos do banco de dados ilegíveis quando os discos são conectados a outro sistema. TLS e VPN protegem dados em trânsito, e um ambiente de execução confiável protege dados em uso.

Questão 7: Alternativa D — TLS mútuo (mTLS) entre serviços

O tráfego serviço a serviço é dado em trânsito, mesmo dentro do data center. TLS mútuo criptografa o tráfego e autentica ambos os serviços, ajudando a impedir ataques man-in-the-middle e movimento lateral. Criptografia de disco completo protege dados em repouso, e enclaves seguros protegem dados em uso.

Questão 8: Alternativa B — BitLocker To Go com uma senha forte ou cartão inteligente

A planilha no pen drive USB é dado em repouso. BitLocker To Go criptografa mídias removíveis e exige autenticação, reduzindo o risco de leitura não autorizada se o drive for perdido. TLS e VPN protegem dados em trânsito, e um enclave seguro protege dados em uso.

Questão 9: Alternativa A — Enclave seguro baseado em hardware ou ambiente de computação confidencial

Chaves sendo processadas na memória são dados em uso. Um enclave seguro baseado em hardware ou ambiente de computação confidencial isola a memória e ajuda a impedir que até administradores privilegiados ou malware extraiam chaves durante o processamento. Criptografia de disco completo protege dados em repouso, TLS protege dados em trânsito, e RAID 6 trata disponibilidade.

Questão 10: Alternativa D — TLS com certificados de servidor e cliente

O requisito é proteger dados em trânsito com integridade e autenticação de origem. TLS com certificados de servidor e cliente criptografa a transferência e usa certificados para autenticar ambas as partes e detectar modificação. Criptografia de disco completo e criptografia de banco de dados protegem dados em repouso, enquanto enclaves seguros protegem dados em uso.